

Cyberster Internship Program

Internship Report

TRACK: BLUE TEAM

NAME: MUHAMMAD RAZA

INSTRUCTOR: ABDULLAH ZIA

ROLL NUMBER: CSI-B1-121

WEEK 5: Malware Analysis and Incident Response

1. Executive Summary

During Week 5 of the Blue Team Internship, a comprehensive malware analysis and detection engineering cycle was conducted. Two distinct malware families, the **Zeus Banking Trojan** and **njRAT (Bladabindi),** were acquired from theZoo repository and analyzed within a strictly isolated, airgapped environment. Analysis spanned static properties, dynamic execution behavior, and network telemetry. The resulting Indicators of Compromise (IOCs) were subsequently utilized to engineer custom network (Suricata) and host-based (Wazuh) detection rules, culminating in a formalized Incident Response (IR) plan aligned with the NIST SP 800-61 framework.

2. Methodology & Environment Isolation

To ensure operational security, all analyses were conducted within an isolated Kali Linux virtual machine.

- **Isolation Strategy:** A dual-layer network airgap was established by disconnecting the VMware NAT adapter and disabling the WAN interface on the pfSense gateway. This prevented outbound internet communication while preserving internal routing for the Wazuh Manager.
- **Sample Handling:** Samples were stored in restricted directories (chmod 700), and executables were stripped of run permissions (chmod 600) during static analysis to prevent accidental detonation.
- **Baseline Capture:** Normal network traffic was recorded via tcpdump to establish a baseline prior to malware detonation.

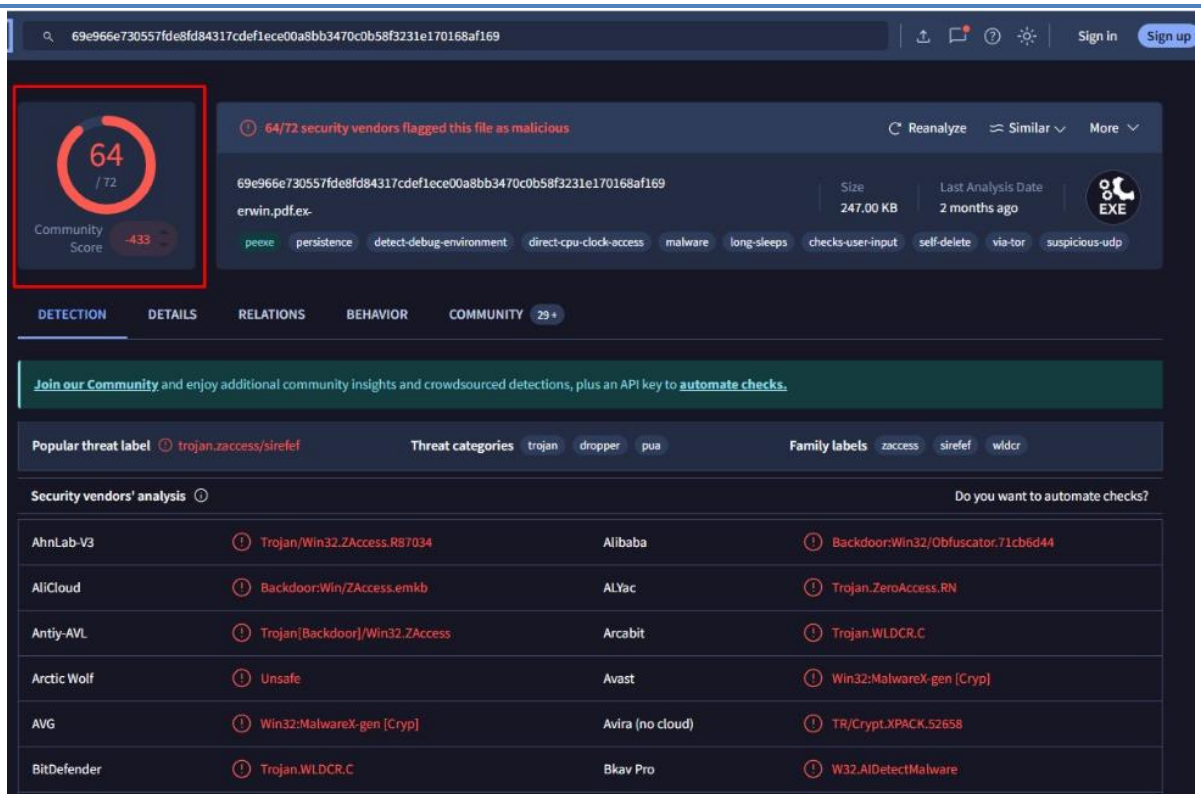
3. Malware Analysis Findings: Zeus Banking Trojan

Sample Identifier (SHA-256):
69e966e730557fde8fd84317cdef1ece00a8bb3470c0b58f3231e170168af169

File Name: invoice_2318362983713_823931342io.pdf.exe (Social engineering via double-extension)

3.1 Static Analysis

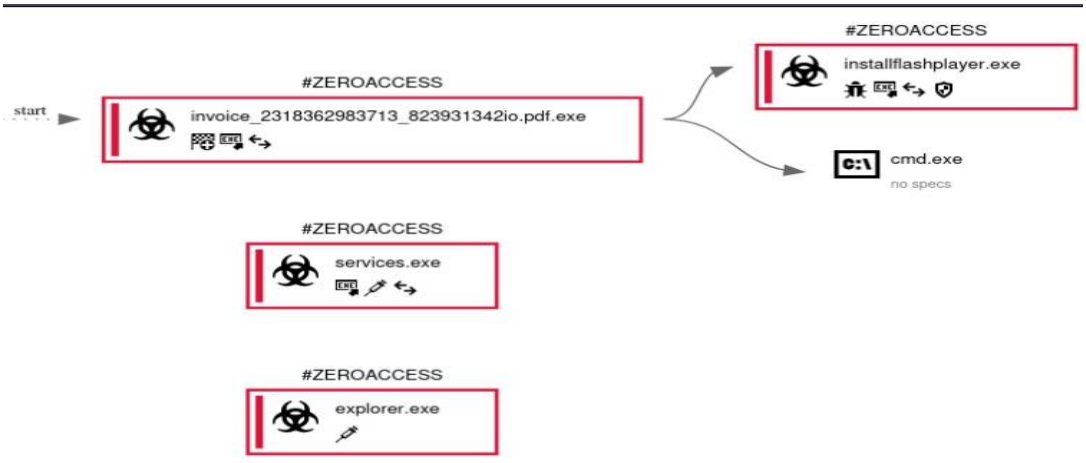
Initial static inspection revealed a 32-bit Windows PE executable compiled in November 2013, masquerading as a PDF. Binwalk identified embedded XML configuration files and packed data segments. Extraction of Unicode strings (strings -el) surfaced extensive references to USER32.dll API functions (e.g., SetDlgItemTextW, GetKeyboardState), heavily indicative of keylogging and form-grabbing capabilities.



3.2 Dynamic Analysis (ANY.RUN)

Upon detonation in the ANY.RUN Windows 7 sandbox, the malware was immediately classified as **ZeroAccess/ZAccess**.

- **Execution & Persistence:** The parent process spawned a command shell and dropped a secondary payload, InstallFlashPlayer.exe, masquerading as an Adobe installer. The malware subsequently hijacked services.exe and injected into explorer.exe.
- **Registry Activity:** Modifications were observed in HKCU\Software\Microsoft\Windows\CurrentVersion\Action Center\Checks and MuiCache.
- **Network Telemetry:** The trojan generated 69 TCP/UDP connections in under 60 seconds. It performed geolocation lookups via j.maxmind.com, attempted to download payloads from fpdownload.macromedia.com (resulting in a 404), and initiated persistent UDP traffic to a suspicious C2 server at 85.114.128.127:53.



4. Malware Analysis Findings: njRAT v0.6.4 (Bladabindi)

Sample Identifier (SHA-256):
fd624aa205517580e83fad7a4ce4d64863e95f62b34ac72647b1974a52822199

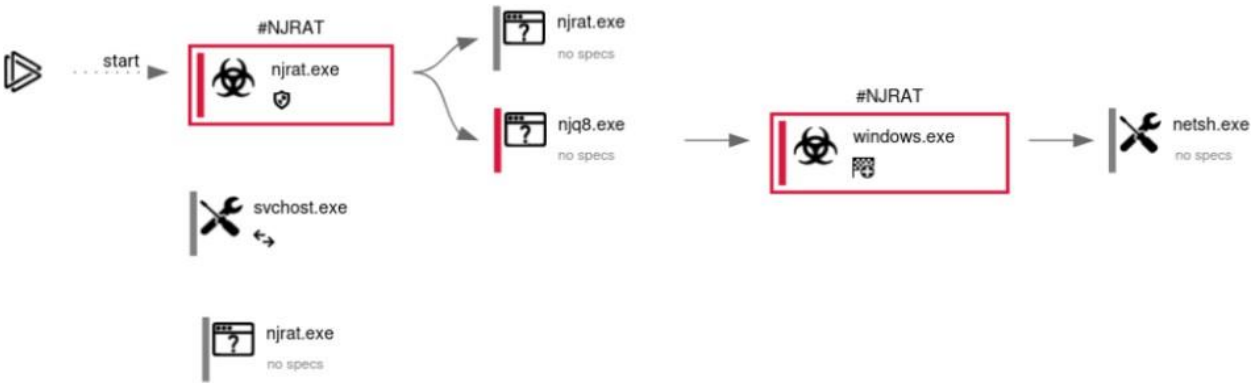
File Name: njRAT.exe

4.1 Static & Dynamic Analysis (ANY.RUN)

njRAT is a prolific Remote Access Trojan compiled via .NET. Detonation in the sandbox confirmed its primary objective: establishing deep system persistence and opening a backdoor for remote attackers.

- **Execution & Persistence:** The initial njrat.exe process dropped copies of itself to C:\njq8.exe and AppData\Local\Temp\windows.exe. To ensure survival across reboots, it copied itself to the Windows Startup folder and modified the HKCU\...\CurrentVersion\Run registry key.
- **Defense Evasion:** A critical finding was the malware executing a command-line instruction via netsh (netsh firewall add allowedprogram... ENABLE) to explicitly whitelist its persistence binary in the Windows Firewall.

Network Telemetry: The malware initiated DNS queries to zaaptoo.zapto.org, a known malicious DynDNS domain utilized for Command and Control (C2) beaconing.





5. Detection Engineering

Behavioral indicators extracted from the analysis were used to author custom detection rules across both network and host-based intrusion detection systems.

5.1 Network Detection (Suricata)

Five custom Suricata rules were written to identify Zeus network activity. Replaying the Zeus PCAP file against these rules successfully validated their efficacy.

1. **SID 1000001:** Detects Zeus C2 DNS Query (j.maxmind.com).
2. **SID 1000002:** Detects suspicious domain queries (fpdownload.macromedia.com).
3. **SID 1000003:** Flags Flash Payload HTTP download attempts.
4. **SID 1000004:** Detects unauthorized UDP DNS communication to 85.114.128.127:53.
5. **SID 1000005:** Identifies anomalous HTTP POST requests indicating potential data exfiltration.

$ cat ~/malware-lab/custom-logs/fast.log

04/08/2026-17:31:54.118056 [**] [1:1000004:1] Zeus DNS Communication to Suspicious IP [**] [Classification: (null)] [Priority: 3] {UDP} 192.168.100.9:49706 -> 85.114.128.127:53
04/08/2026-17:31:57.054861 [**] [1:1000002:1] Zeus Suspicious Domain - fpdownload.macromedia.com [**] [Classification: (null)] [Priority: 3] {UDP} 192.168.100.9:62655 -> 192.168.100.2:53
04/08/2026-17:31:54.107019 [**] [1:1000004:1] Zeus DNS Communication to Suspicious IP [**] [Classification: (null)] [Priority: 3] {UDP} 192.168.100.9:49704 -> 85.114.128.127:53
04/08/2026-17:31:55.158309 [**] [1:1000004:1] Zeus DNS Communication to Suspicious IP [**] [Classification: (null)] [Priority: 3] {UDP} 192.168.100.9:49711 -> 85.114.128.127:53
04/08/2026-17:31:54.118461 [**] [1:1000004:1] Zeus DNS Communication to Suspicious IP [**] [Classification: (null)] [Priority: 3] {UDP} 192.168.100.9:49707 -> 85.114.128.127:53
04/08/2026-17:31:54.118666 [**] [1:1000004:1] Zeus DNS Communication to Suspicious IP [**] [Classification: (null)] [Priority: 3] {UDP} 192.168.100.9:49708 -> 85.114.128.127:53
04/08/2026-17:31:56.893215 [**] [1:1000004:1] Zeus DNS Communication to Suspicious IP [**] [Classification: (null)] [Priority: 3] {UDP} 192.168.100.9:49712 -> 85.114.128.127:53
04/08/2026-17:31:54.078512 [**] [1:1000001:1] Zeus C2 DNS Query - j.maxmind.com [**] [Classification: (null)] [Priority: 3] {UDP} 192.168.100.9:49703 -> 8.8.8.8:53
04/08/2026-17:31:54.110093 [**] [1:1000004:1] Zeus DNS Communication to Suspicious IP [**] [Classification: (null)] [Priority: 3] {UDP} 192.168.100.9:49705 -> 85.114.128.127:53
04/08/2026-17:31:54.118826 [**] [1:1000004:1] Zeus DNS Communication to Suspicious IP [**] [Classification: (null)] [Priority: 3] {UDP} 192.168.100.9:49709 -> 85.114.128.127:53
04/08/2026-17:31:54.126721 [**] [1:1000004:1] Zeus DNS Communication to Suspicious IP [**] [Classification: (null)] [Priority: 3] {UDP} 192.168.100.9:49710 -> 85.114.128.127:53
04/08/2026-17:31:54.078512 [**] [1:1000001:1] Zeus C2 DNS Query - j.maxmind.com [**] [Classification: (null)] [Priority: 3] {UDP} 192.168.100.9:49703 -> 8.8.8.8:53
04/08/2026-17:31:54.107019 [**] [1:1000004:1] Zeus DNS to Suspicious IP [**] [Classification: (null)] [Priority: 3] {UDP} 192.168.100.9:49704 -> 85.114.128.127:53
04/08/2026-17:31:54.110093 [**] [1:1000004:1] Zeus DNS to Suspicious IP [**] [Classification: (null)] [Priority: 3] {UDP} 192.168.100.9:49705 -> 85.114.128.127:53
04/08/2026-17:31:54.118461 [**] [1:1000004:1] Zeus DNS to Suspicious IP [**] [Classification: (null)] [Priority: 3] {UDP} 192.168.100.9:49707 -> 85.114.128.127:53
04/08/2026-17:31:54.118666 [**] [1:1000004:1] Zeus DNS to Suspicious IP [**] [Classification:

(null)] [Priority: 3] {UDP} 192.168.100.9:49708 -> 85.114.128.127:53
04/08/2026-17:31:56.893215 [**] [1:1000004:1] Zeus DNS to Suspicious IP [**] [Classification: (null)] [Priority: 3] {UDP} 192.168.100.9:49712 -> 85.114.128.127:53
04/08/2026-17:32:19.788556 [**] [1:1000003:1] Zeus Flash Payload Download Attempt [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.100.9:50018 -> 23.197.137.122:80
04/08/2026-17:31:54.118056 [**] [1:1000004:1] Zeus DNS to Suspicious IP [**] [Classification: (null)] [Priority: 3] {UDP} 192.168.100.9:49706 -> 85.114.128.127:53
04/08/2026-17:31:54.118826 [**] [1:1000004:1] Zeus DNS to Suspicious IP [**] [Classification: (null)] [Priority: 3] {UDP} 192.168.100.9:49709 -> 85.114.128.127:53
04/08/2026-17:31:54.126721 [**] [1:1000004:1] Zeus DNS to Suspicious IP [**] [Classification: (null)] [Priority: 3] {UDP} 192.168.100.9:49710 -> 85.114.128.127:53
04/08/2026-17:31:57.054861 [**] [1:1000002:1] Zeus Suspicious Domain - fpdownload.macromedia.com [**] [Classification: (null)] [Priority: 3] {UDP} 192.168.100.9:62655 -> 192.168.100.2:53
04/08/2026-17:31:57.372316 [**] [1:1000003:1] Zeus Flash Payload Download Attempt [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.100.9:50008 -> 23.197.137.122:80

5.2 Host Detection (Wazuh)

To capture behaviors missed by network monitoring, three custom Wazuh rules were deployed:

- **Rule 100200:** Detects Registry Persistence (modifications to CurrentVersion\Run).
- **Rule 100201:** Detects suspicious spawned cmd.exe execution chains.
- **Rule 100202:** Alerts on anomalous executable file drops in AppData\Local\Temp.

6. Incident Response Plan (NIST SP 800-61)

Phase 1: Preparation

- Maintain updated Suricata and Wazuh rules based on the latest threat intelligence.
- Ensure immediate access to airgapped forensic environments and cloud sandboxes (ANY.RUN).

Phase 2: Detection and Analysis

- Correlate Suricata network alerts (C2 beaconing, payload downloads) with Wazuh host alerts (registry persistence, anomalous netsh execution).
- Verify payload hashes against VirusTotal and isolate suspected binaries for sandbox detonation.

Phase 3: Containment, Eradication, and Recovery

- **Containment:** Immediately logically isolate the infected endpoint from the corporate LAN. Implement perimeter firewall blocks for identified C2 IPs (85.114.128.127) and DNS blackholes for domains (*.zapto.org, fpdownload.macromedia.com).
- **Eradication:** Terminate malicious processes (e.g., rogue windows.exe, InstallFlashPlayer.exe). Purge dropped payloads from AppData and Startup directories. Strip malicious Run keys from the registry and revert unauthorized netsh firewall exceptions.
- **Recovery:** Reimage the compromised host from a known-good backup if deep system compromise (like ZeroAccess rootkit behavior) is suspected. Monitor the restored machine continuously for 72 hours. Force credential resets for the affected user.

Phase 4: Post-Incident Activity

- Conduct a blameless post-mortem. Update detection logic and threat intelligence platforms with newly discovered IOCs. Revise network segmentation policies to hinder future lateral movement.

Appendix: Consolidated Indicators of Compromise (IOCs)

Indicator Type	Value	Associated Threat	Source
Hash (SHA-256)	69e966e730557fde8fd84317cdef1ece00a8bb3470c0b58f3231e170168af169	Zeus Banking Trojan	Static Analysis
Hash (SHA-256)	fd624aa205517580e83fad7a4ce4d64863e95f62b34ac72647b1974a52822199	njRAT v0.6.4	Static Analysis
Domain	zaaptoo.zapto.org	njRAT C2	Dynamic Analysis
Domain	fpdownload.macromedia.com	Zeus Payload Server	Dynamic Analysis
IP Address	85.114.128.127:53	Zeus C2 / DNS	Dynamic Analysis
File Path	C:\Users\Raza\AppData\Local\Temp\windows.exe	njRAT Payload Drop	Dynamic Analysis
Command Line	netsh firewall add allowedprogram... ENABLE	njRAT Evasion	Dynamic Analysis
Registry Key	HKCU\Software\Microsoft\Windows\CurrentVersion\Run	njRAT Persistence	Dynamic Analysis